

Universidad Europea de Madrid

Laboratorio de Hacking

Practica 1 - Reconocimiento pasivo (OSINT)

Empresa objetivo: **MAPFRE, S.A.** (IBEX 35)

Autor/a: Adrian Garcia Mejias

Titulacion: Grado en Ingenieria Informatica

Asignatura: Laboratorio de Hacking

Fecha de entrega: 21 de marzo

Resumen

Este trabajo recoge una investigacion de tipo OSINT (inteligencia de fuentes abiertas) sobre la aseguradora espanola MAPFRE, S.A., cotizada en el IBEX 35. El objetivo no es «hackear» ni acceder a ningun sistema de la compania, sino averiguar que informacion sobre su infraestructura tecnologica y su organizacion ya es visible publicamente en Internet, sin necesidad de vulnerar ninguna proteccion.

En terminos sencillos: cuando una empresa registra un dominio de Internet, solicita certificados de seguridad para sus paginas web, contrata proveedores externos (correo, publicidad, alojamiento web) o sus empleados hablan de su trabajo en redes sociales como LinkedIn, deja un rastro que cualquiera puede recorrer con herramientas gratuitas y sin saltarse ninguna barrera de seguridad. Este documento reconstruye parte de ese rastro para MAPFRE: quien es el propietario legal de sus dominios, que empresas externas usa para alojar su web y gestionar su correo, en que paises esta su infraestructura tecnica frente a donde se entrega su pagina web al usuario final, cuantos «nombres internos» de sus sistemas han quedado visibles de forma indirecta, y que dominios de marca menos conocidos (como un club de fidelizacion de clientes) forman parte de su ecosistema digital.

Los resultados muestran que MAPFRE cuenta con practicas de seguridad razonables (proteccion de sus datos de contacto, filtros anti-fraude en su correo, ocultacion de detalles tecnicos de sus servidores), pero que su enorme presencia digital – activa en mas de 40 paises – deja visibles cientos de nombres tecnicos internos, asi como cerca de una decena de direcciones de correo de empleados, informacion que en si misma no supone una vulnerabilidad, pero que si reduce el «efecto sorpresa» del que dispondria alguien con malas intenciones y que, por tanto, merece atencion por parte del equipo de seguridad de la empresa.

Indice

Resumen	2
1 Investigacion de registros DNS	4
1.1 Funcion de los principales tipos de registro	4
1.2 Reconocimiento pasivo vs. activo en consultas DNS	4
2 Introduccion	5
3 Desarrollo	6
3.1 Modelo de negocio de MAPFRE	6
3.2 Metodologia y herramientas empleadas	6
3.2.1 Minimizacion de datos y buenas practicas de reporting	6
3.3 Reconocimiento de dominio (WHOIS / RDAP)	6
3.4 Registros DNS y huella de proveedores SaaS	7
3.5 Enumeración de subdominios (Certificate Transparency)	7
3.6 Infraestructura CDN	8
3.7 Huella digital geografica	9
3.8 Dispositivos y servicios expuestos (Shodan)	10
3.9 Presencia en redes sociales	12
3.10 Google Dorking	13
4 Resultados	16
4.1 Identidad y registro de dominios	17
4.2 Proveedores SaaS identificados vía registros DNS TXT	17
4.3 Categorías de subdominios expuestos (crt.sh)	17
5 Conclusiones	18
6 Bibliografia	18

1 Investigacion de registros DNS

El Sistema de Nombres de Dominio (DNS) traduce nombres legibles por personas en datos que las maquinas necesitan para operar (direcciones IP, servidores de correo, politicas de validacion, etc.). Es, ademas, una de las fuentes de informacion mas ricas en la fase inicial de cualquier auditoria, ya que su consulta es publica por diseno.

1.1 Funcion de los principales tipos de registro

A Asocia un nombre de dominio con una direccion IPv4. Es el registro mas basico de resolucion de nombres.

AAAA Equivalente al registro A pero para direcciones IPv6.

MX (Mail Exchange) Indica que servidores gestionan el correo entrante de un dominio, junto con su prioridad. Revela el proveedor de correo (Microsoft 365, Google Workspace, servidor propio, etc.).

TXT Registro de texto libre usado para multiples propositos: politicas anti-spoofing (SPF), verificacion de propiedad de dominio ante terceros (Google, Facebook, Adobe...), o claves publicas (DKIM). Es una fuente muy valiosa de OSINT, como se ha visto en este mismo informe.

CNAME (Canonical Name) Crea un alias de un nombre de dominio hacia otro nombre canonico. Habitual para apuntar subdominios a servicios de terceros (CDN, plataformas SaaS) sin exponer directamente su IP.

NS (Name Server) Indica que servidores son autoritativos para resolver las consultas DNS de ese dominio.

SOA (Start of Authority) Contiene metadatos administrativos de la zona DNS (servidor primario, email del administrador, numero de serie, temporizadores de refresco/reintento/caducidad). Es el primer registro que se consulta al transferir o depurar una zona.

PTR (Pointer) Realiza la resolucion inversa, de direccion IP a nombre de dominio. Se usa, entre otros fines, para verificar la legitimidad de servidores de correo saliente.

1.2 Reconocimiento pasivo vs. activo en consultas DNS

La consulta de estos registros mediante herramientas como **dig**, **nslookup** o **host** contra un **resolutor DNS publico** (por ejemplo, el resolutor de tu proveedor de Internet, o uno publico como 8.8.8.8 o 1.1.1.1) se considera reconocimiento **pasivo**: el cliente nunca establece una conexion directa con la infraestructura de la organizacion objetivo, sino que pregunta a un tercero (el resolutor) que ya tiene, o va a obtener por su cuenta, esa informacion. La organizacion objetivo no puede, en general, distinguir esa consulta de cualquier otra consulta legitima de un usuario normal navegando su web o enviandole un correo.

Esta misma actividad se convierte en reconocimiento **activo** en cuanto se interactua directamente con la infraestructura DNS de la organizacion, por ejemplo:

- Realizando una consulta directamente contra los servidores de nombres autoritativos de la empresa (**dig @esdns1.mapfre.net mapfre.com ANY**), en lugar de contra un resolutor publico.
- Intentando una **transferencia de zona** (**dig axfr**), que solicita al servidor autoritativo el volcado completo de todos los registros de la zona; si el servidor esta mal configurado y lo permite, esto revela de golpe toda la topologia interna del dominio.
- Realizando **fuerza bruta de subdominios** (probar miles de nombres candidatos contra el DNS de la organizacion para ver cuales resuelven), que si bien tecnicamente son consultas DNS individuales, en conjunto constituyen un patron de trafico anomalo, facilmente detec-

table por sistemas de monitorizacion, y por tanto se considera una tecnica activa y no autorizada en el contexto de esta practica.

Por este motivo, en el reconocimiento realizado sobre MAPFRE en este informe se ha optado deliberadamente por la enumeracion de subdominios via **Certificate Transparency** (crt.sh) en lugar de fuerza bruta de DNS: ambas tecnicas persiguen el mismo objetivo (descubrir subdominios), pero la primera es estrictamente pasiva (consulta un registro publico ya existente) mientras que la segunda seria activa (genera trafico dirigido contra la infraestructura objetivo).

2 Introduccion

La fase de reconocimiento (*reconnaissance*) es la primera etapa de cualquier metodologia de ciberseguridad ofensiva. Dentro de ella se distingue habitualmente entre reconocimiento **activo** (que implica interactuar directamente con los sistemas objetivo, por ejemplo escaneando puertos o forzando subdominios por fuerza bruta) y reconocimiento **pasivo**, que se limita a recopilar informacion ya publicada por terceros – registradores de dominios, autoridades de certificacion, buscadores, redes sociales, motores de indexacion de dispositivos como Shodan – sin establecer en ningun momento una conexion que el objetivo pueda distinguir de trafico legitimo de un usuario cualquiera.

Esta practica se ciñe estrictamente a este segundo enfoque, tal y como exige el enunciado de la asignatura: queda expresamente prohibido el uso de tecnicas de recogida de informacion activa (escaneos de puertos con herramientas como nmap, ataques de fuerza bruta, o enumeracion de directorios mediante fuzzing) sobre los activos de la empresa seleccionada. Todo el contenido de este informe se ha obtenido mediante consultas a fuentes publicas y de solo lectura: WHOIS/RDAP, resolucion DNS contra resolutores publicos, logs de Certificate Transparency, buscadores web y de dispositivos (Google, Shodan), y redes sociales profesionales.

La empresa seleccionada es **MAPFRE, S.A.**, asignada segun el reparto publicado en el foro de la asignatura. MAPFRE es una aseguradora y reaseguradora multinacional espanola, fundada en 1933, con sede en Majadahonda (Madrid), que cotiza en el IBEX 35 y opera en mas de 40 paises, siendo lider del sector asegurador en Espana y una de las principales aseguradoras no vida de Latinoamerica.

Los objetivos concretos de esta practica son:

1. Investigar los principales tipos de registro DNS y discutir bajo que condiciones su consulta constituye reconocimiento pasivo o activo.
2. Introducir el modelo de negocio de MAPFRE (clientes, proveedores, servicios ofrecidos).
3. Identificar los servicios y tecnologias expuestos por la organizacion (web, correo, proveedores SaaS).
4. Determinar su infraestructura tecnica y los proveedores que la soportan (registrador de dominio, CDN, hosting).
5. Trazar su huella digital geografica.
6. Enumerar de forma pasiva su exposicion de activos (subdominios, certificados, dispositivos indexados).
7. Revisar su presencia en redes sociales profesionales.
8. Ilustrar, con tres ejemplos originales, el uso de Google Dorking como tecnica de reconocimiento pasivo.

En ningun momento de esta practica se han realizado escaneos de puertos, intentos de explotacion, pruebas de intrusion, ingenieria social dirigida a personas concretas ni ningun otro tipo

de actividad activa contra los sistemas de MAPFRE. Todos los datos presentados proceden de fuentes publicas y de acceso libre, ya indexadas por terceros con anterioridad a la realizacion de este trabajo.

3 Desarrollo

3.1 Modelo de negocio de MAPFRE

MAPFRE, S.A. es una aseguradora y reaseguradora multinacional española, fundada en 1933 y con sede en Majadahonda (Madrid), que cotiza en el IBEX 35. Opera en mas de 40 países y es lider del mercado asegurador en España, además de una de las principales aseguradoras no vida de Latinoamérica.

Clientes particulares y empresas que contratan pólizas de vida, auto, hogar, salud, empresas y riesgos globales, así como productos de ahorro e inversión a través de su gestora. Su base de clientes abarca desde el mercado minorista domestico hasta grandes cuentas corporativas e industriales (MAPFRE Global Risks).

Proveedores talleres y redes de reparación de vehículos, centros médicos y hospitales concertados, mediadores y agentes de seguros (canal de distribución clave del negocio asegurador), proveedores tecnológicos (los identificados en este mismo informe: Microsoft, AWS, Atlasian, Dynatrace, Adobe, Proofpoint, Mailjet), y reaseguradoras internacionales con las que MAPFRE RE comparte riesgo.

Servicio que ofrece seguros directos (vida y no vida) y reaseguro, gestión de siniestros y asistencia (MAPFRE Asistencia), y servicios de ahorro e inversión. Su modelo de negocio no produce bienes físicos, sino que transforma primas cobradas en cobertura de riesgo y servicios de asistencia asociados (grúa, reparación, atención médica, gestión de siniestros, etc.).

3.2 Metodología y herramientas empleadas

El reconocimiento se ha estructurado en varios bloques de trabajo (WHOIS/RDAP, DNS, Certificate Transparency, OSINT sobre personas y organización), cada uno apoyado en herramientas o fuentes públicas específicas, detalladas en cada subsección correspondiente.

3.2.1 Minimización de datos y buenas practicas de reporting

Durante la fase de enumeración de subdominios se identificaron de forma incidental varias direcciones de correo de empleados, expuestas como efecto colateral de la emisión de certificados S/MIME. Aunque técnicamente forman parte de la información pública recuperada, este informe sigue el principio de **minimización de datos**: se documenta su existencia y el patrón de nomenclatura observado, pero no se reproducen las direcciones de forma literal.

Esta decisión responde a una práctica profesional habitual en la elaboración de informes de seguridad ofensiva (pentesting, red team, auditorías OSINT): un informe de reconocimiento debe demostrar que es recuperable y cual es su impacto potencial (por ejemplo, de cara a una campaña de phishing dirigido), sin convertirse el mismo en una nueva fuente de fuga de datos personales. En otras palabras, el objetivo de este documento es evidenciar el riesgo, no maximizar la exposición de las personas afectadas.

3.3 Reconocimiento de dominio (WHOIS / RDAP)

La consulta WHOIS realizada con `whois mapfre.com` confirma que el dominio fue registrado el 16 de marzo de 1996 y permanece activo, con vencimiento el 17 de marzo de 2027. El registrador es **Acens Technologies, S.L.U.**, proveedor español de servicios de hosting y dominios. La

resolución de nombres recae en tres servidores propios bajo su propio dominio corporativo (`esdns1`, `esdns2` y `esdns3.mapfre.net`), lo que indica que la organización gestiona su propia infraestructura de DNS autoritativo en lugar de delegarla en un tercero.

A diferencia de consultas WHOIS históricas sobre el mismo dominio, en las que el campo de organización registrante aparecía como **MAPFRE INTERNET, S.A.**, la consulta actual devuelve el valor **REDACTED FOR PRIVACY**. Esto sugiere que la organización ha activado en algún momento un servicio de protección de privacidad WHOIS sobre sus datos de contacto, una práctica de higiene de seguridad recomendable que dificulta la recolección directa de contactos humanos a partir de este vector, aunque no afecta a la información de infraestructura (servidores de nombres, registrador, fechas) [1].

3.4 Registros DNS y huella de proveedores SaaS

La resolución de los registros NS, MX, TXT y A de `mapfre.com` mediante `dig` aporta información adicional relevante. El correo corporativo se gestiona a través de **Microsoft 365 / Exchange Online Protection** (`mapfre-com.mail.protection.outlook.com`), y al menos una parte de la infraestructura web resuelve a una dirección IP dentro del rango de **Amazon Web Services** en la región de Irlanda (`54.171.208.217`).

El registro SPF publicado (`v=spf1 include:mpfsr.com include:spf.mailjet.com -all`) aplica una política estricta de rechazo (`-all`), lo que dificulta la suplantación del dominio en correos fraudulentos, e incluye explícitamente a **Mailjet** como proveedor autorizado de envío de correo transaccional o de marketing.

Los numerosos registros TXT de verificación de propiedad de dominio permiten, sin necesidad de acceder a ningún sistema, inventariar proveedores SaaS con los que MAPFRE mantiene una relación contractual: Google Search Console, Apple Business/App verification y Facebook Business Manager (marketing y presencia digital); **Dynatrace** (observabilidad y monitorización de aplicaciones); **Adobe Identity Provider** (gestión de identidad, posiblemente ligada a Adobe Experience Cloud); **Atlassian** (herramientas de gestión de proyectos y documentación, típicamente Jira/Confluence); y **Proofpoint**, una pasarela de seguridad de correo electrónico especializada en la detección de phishing y spam dirigido. Esta técnica ilustra cómo el propio DNS de una organización, sin intención alguna de exponer información sensible, termina revelando de forma indirecta su ecosistema de proveedores tecnológicos [2].

3.5 Enumeración de subdominios (Certificate Transparency)

La consulta a `crt.sh` sobre el dominio exacto `mapfre.com` (evitando el comodín `%.mapfre.com`, que la propia base de datos del servicio rechazó por sobrecarga, tal y como advierte su mensaje de error: *«searches that would produce many results may never succeed»*) permitió recuperar más de 1,7 MB de registros de certificados históricos, de los que se extrajeron **527 nombres de host únicos** [3].

El análisis de estos 527 subdominios revela una superficie de ataque considerablemente mayor que la sugerida por el dominio principal. En torno al 37% (196 hosts) siguen el patrón `*.devops.mapfre.com`, con segmentos `dev`, `pre`, `pro` y `probis` replicados para distintas unidades de negocio y países del grupo (Brasil, México, Perú, Malta, Turquía, Italia, Francia, República Dominicana, entre otros), lo que confirma una plataforma de integración continua centralizada y multi-país. Un segundo bloque relevante (27 hosts) corresponde a la plataforma de aprendizaje automático interna, identificada por el nombre en clave «Atenea» sobre AWS (`mlops.atenea.app.*.aws.mapfre.com`), replicada por país y por entorno.

También se identifican indicios claros de un despliegue de **Exchange híbrido** on-premise (`autodiscover`, `lyncdiscover`, `extowaweb`, `hybridcas`, `hybridedge`), de una plataforma de infraestructura de escritorio virtual (`vdi`, `virtualapps`, `pocvdi`), de puntos de autenticación única (`securelogin`, y varios subdominios `*sso`), y de un stack de DevOps y observabilidad completo expuesto por nombre de host: Ansible Tower, Jenkins, ArgoCD, Grafana, Kibana/ELK y Prometheus. Los subdominios `click.comunica`, `view.comunica`, `image.comunica` y `cloud.comunica` siguen un patrón de nomenclatura característico de **Salesforce Marketing Cloud**, lo que sugiere su uso como plataforma de email marketing.

Por último, el propio listado de certificados reveló, de forma incidental, un pequeño número de direcciones de correo corporativo de empleados (aproximadamente una decena), incluidas en el campo de certificados de tipo S/MIME. Todas siguen el mismo patrón de nomenclatura (inicial del nombre + primer apellido, `@mapfre.com`), lo que por sí mismo constituye información útil para un atacante que quisiera construir direcciones de correo plausibles para una campaña de *phishing* dirigido. Por motivos de minimización de datos, este informe no reproduce dichas direcciones de forma literal, limitándose a documentar su existencia y el patrón de nomenclatura observado.

3.6 Infraestructura CDN

La resolución del alias `www.mapfre.com` revela que la web pública corporativa no apunta directamente a una dirección IP de MAPFRE, sino a una distribución de **Amazon CloudFront** (`d2bu2h5rbbie6u.cloudfront.net`), el servicio de CDN de AWS. Las cabeceras HTTP de respuesta confirman este hecho de forma explícita (`x-cache: Hit from cloudfront`, `x-amz-cf-pop: MAD53-P5`), indicando además que la petición fue atendida desde el nodo de CloudFront situado en Madrid, el más cercano geográficamente al punto de consulta (ver Figura 1).

La cabecera `content-security-policy` de la respuesta, además, enumera de forma incidental otros dominios y marcas relacionadas con MAPFRE que no habían aparecido en el resto de fuentes consultadas: `mapfre.es`, `mapfretecuidamos` y `digitalhealth.com`, lo que abre una vía adicional de investigación sobre el ecosistema digital del grupo más allá del dominio `mapfre.com`. Por otro lado, la cabecera `server` se devuelve vacía de forma deliberada, ocultando la tecnología del servidor de origen tras el CDN, una práctica de **hardening** que dificulta el fingerprinting tecnológico directo del backend.


```
adr3d0@adr3d0: ~/Laboratorio1-hacking-uem/P1_Reco...
$ dig www.mapfre.com CNAME +short && echo "---" && dig www.mapfre.com A +short && echo "---" && curl -sI https://www.mapfre.com | head -30
d2bu2h5rbbie6u.cloudfront.net.
---
d2bu2h5rbbie6u.cloudfront.net.
13.33.243.46
13.33.243.110
13.33.243.45
13.33.243.124
---
HTTP/2 200
content-type: text/html
content-length: 295002
date: Mon, 06 Jul 2026 10:51:18 GMT
content-security-policy: frame-ancestors 'self' *.mapfre.com *.mapfre.es *.mapfretecuidamos *.digitalhealth.com;
server:
strict-transport-security: max-age=31536000; includeSubDomains;
x-frame-options: SAMEORIGIN
last-modified: Thu, 02 Jul 2026 12:06:36 GMT
etag: "4805a-6559fa3cb1db3"
accept-ranges: bytes
cache-control: max-age=3600, public
expires: Mon, 06 Jul 2026 11:51:18 GMT
a-id: 5ed25a
via: 1.1 proxy.companyx.com Squid/2.4.STABLE7, 1.1 c711339a215e22be3f81ff604676c1e2.cloudfront.net (CloudFront)
access-control-allow-origin: www.mapfre.com
x-content-type-options: nosniff
x-xss-protection: 1; mode=block
vary: Accept-Encoding
x-cache: Hit from cloudfront
x-amz-cf-pop: MAD53-P5
x-amz-cf-id: ph9fx3n3p04Imo-IffGaexb9wHYsoHchGLt4CB_nEuI38bBvVKjl2Q==
age: 2632
```

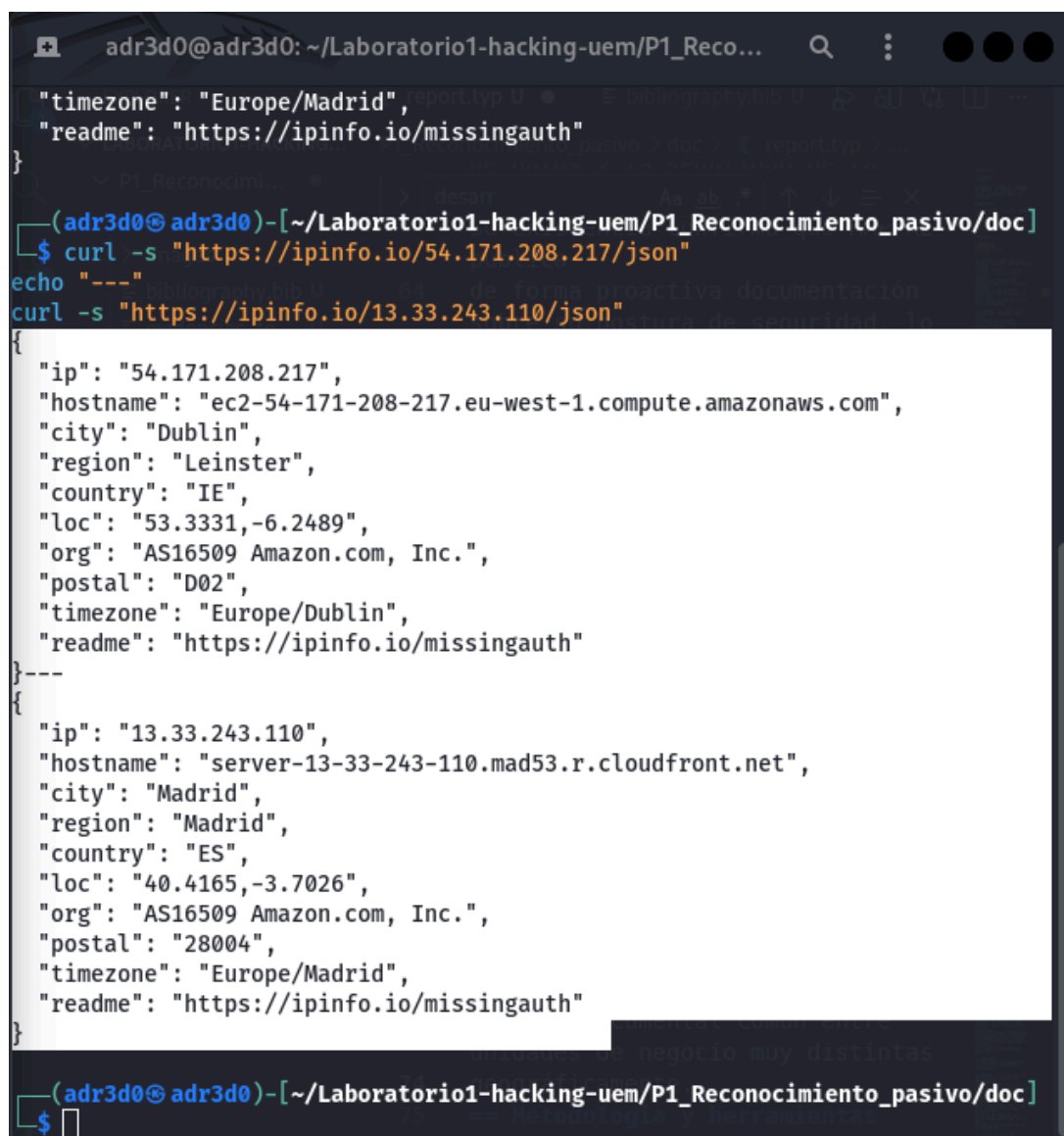
Figura 1: Resolución DNS de `www.mapfre.com` y cabeceras HTTP de respuesta, mostrando el uso de Amazon CloudFront como CDN.

3.7 Huella digital geografica

La geolocalización de las direcciones IP identificadas en este informe permite trazar una huella geográfica clara. La IP asociada al registro A de `mapfre.com` (54.171.208.217) se ubica en **Dublin, Irlanda**, dentro del rango de Amazon Web Services (region eu-west-1), mientras que los nodos que sirven `www.mapfre.com` a través de CloudFront resuelven, para un usuario situado en España, a un punto de presencia en **Madrid** (13.33.243.110), coincidiendo con la sede corporativa del grupo en Majadahonda [4].

Esta discrepancia ilustra una característica típica de las arquitecturas con CDN: el **origen técnico** de una aplicación (Irlanda, en este caso) puede no coincidir con el **punto de entrega** al usuario final (Madrid), ya que el CDN sirve el contenido desde el nodo geográficamente más cercano a quien realiza la petición. Sumado a los más de una decena de países identificados en los subdominios de entorno **devops** (Brasil, México, Perú, Malta, Turquía, Italia, Francia, República Dominicana, entre otros), la huella geográfica de MAPFRE queda descrita como: sede corporativa y punto de entrega principal en Madrid, infraestructura cloud de respaldo en

Irlanda, y entornos técnicos replicados en, al menos, una decena de países donde el grupo opera comercialmente.



```
adr3d0@adr3d0: ~/Laboratorio1-hacking-uem/P1_Reco...
"timezone": "Europe/Madrid",
"readme": "https://ipinfo.io/missingauth"
}

(adr3d0@adr3d0)-[~/Laboratorio1-hacking-uem/P1_Reconocimiento_pasivo/doc]
$ curl -s "https://ipinfo.io/54.171.208.217/json"
echo "---"
curl -s "https://ipinfo.io/13.33.243.110/json"
{
  "ip": "54.171.208.217",
  "hostname": "ec2-54-171-208-217.eu-west-1.compute.amazonaws.com",
  "city": "Dublin",
  "region": "Leinster",
  "country": "IE",
  "loc": "53.3331,-6.2489",
  "org": "AS16509 Amazon.com, Inc.",
  "postal": "D02",
  "timezone": "Europe/Dublin",
  "readme": "https://ipinfo.io/missingauth"
}---
{
  "ip": "13.33.243.110",
  "hostname": "server-13-33-243-110.mad53.r.cloudfront.net",
  "city": "Madrid",
  "region": "Madrid",
  "country": "ES",
  "loc": "40.4165,-3.7026",
  "org": "AS16509 Amazon.com, Inc.",
  "postal": "28004",
  "timezone": "Europe/Madrid",
  "readme": "https://ipinfo.io/missingauth"
}

(adr3d0@adr3d0)-[~/Laboratorio1-hacking-uem/P1_Reconocimiento_pasivo/doc]
$
```

Figura 2: Geolocalización de las direcciones IP de origen (Dublin, AWS) y de entrega vía CDN (Madrid, CloudFront) obtenida con ipinfo.io.

3.8 Dispositivos y servicios expuestos (Shodan)

La consulta org: "MAPFRE" en **Shodan** – un motor de búsqueda que indexa banners de servicios expuestos en Internet mediante escaneos masivos propios, de forma que consultarlo es tan pasivo como usar cualquier buscador web – devuelve varios miles de resultados distribuidos por país, entre los que destacan Reino Unido, España, Estados Unidos, Brasil y Francia [5] (ver Figura 3).

Un análisis crítico de estos resultados es imprescindible: el peso inicialmente sorprendente de Reino Unido se explica al revisar el listado de organizaciones asociadas, donde aparece «**Mapfre Abraxas & Insure and Go**», confirmando que corresponde a una filial británica real del grupo (especializada en seguros de viaje) y no a un falso positivo. Sin embargo, no todos los resultados son igual de fiables: la IP 195.235.248.56, aunque catalogada bajo **MAPFRE INTERNET, S.A.** en Madrid, devuelve un banner de advertencia de acceso no autorizado que pertenece textualmente a otra organización («Southern Communications Ltd.»), un artefacto

habitual en Shodan cuando un rango de IP ha sido reasignado y el banner cacheado no se ha actualizado. Este caso ilustra la necesidad de contrastar cada hallazgo individualmente antes de darlo por valido, en lugar de asumir que todo resultado devuelto por una busqueda por nombre de organizacion pertenece realmente a la empresa objetivo.

Por el contrario, la IP 195.235.248.194 si constituye un hallazgo solido y verificable: aloja el servidor `sistweb.mapfre.com / www.sistweb.mapfre.com`, ejecutando **Apache** como servidor web, con un certificado SSL emitido por GeoTrust/DigiCert a nombre de **MAPFRE, S.A.** en Madrid – coherencia total entre IP, nombre de host, certificado y organizacion, sin senales de reasignacion o ruido.

Entre los puertos mas frecuentes en el conjunto de resultados destacan el 443 y el 80 (trafico web estandar, esperable), pero tambien el 5060 y 5090 (protocolo **SIP**, senal de infraestructura de telefonía IP/VoIP expuesta) y el 179 (**BGP**, protocolo de enrutamiento entre sistemas autonomos), cuya exposicion publica es menos habitual y podria merecer una revision de configuracion por parte del equipo de seguridad de la compania.

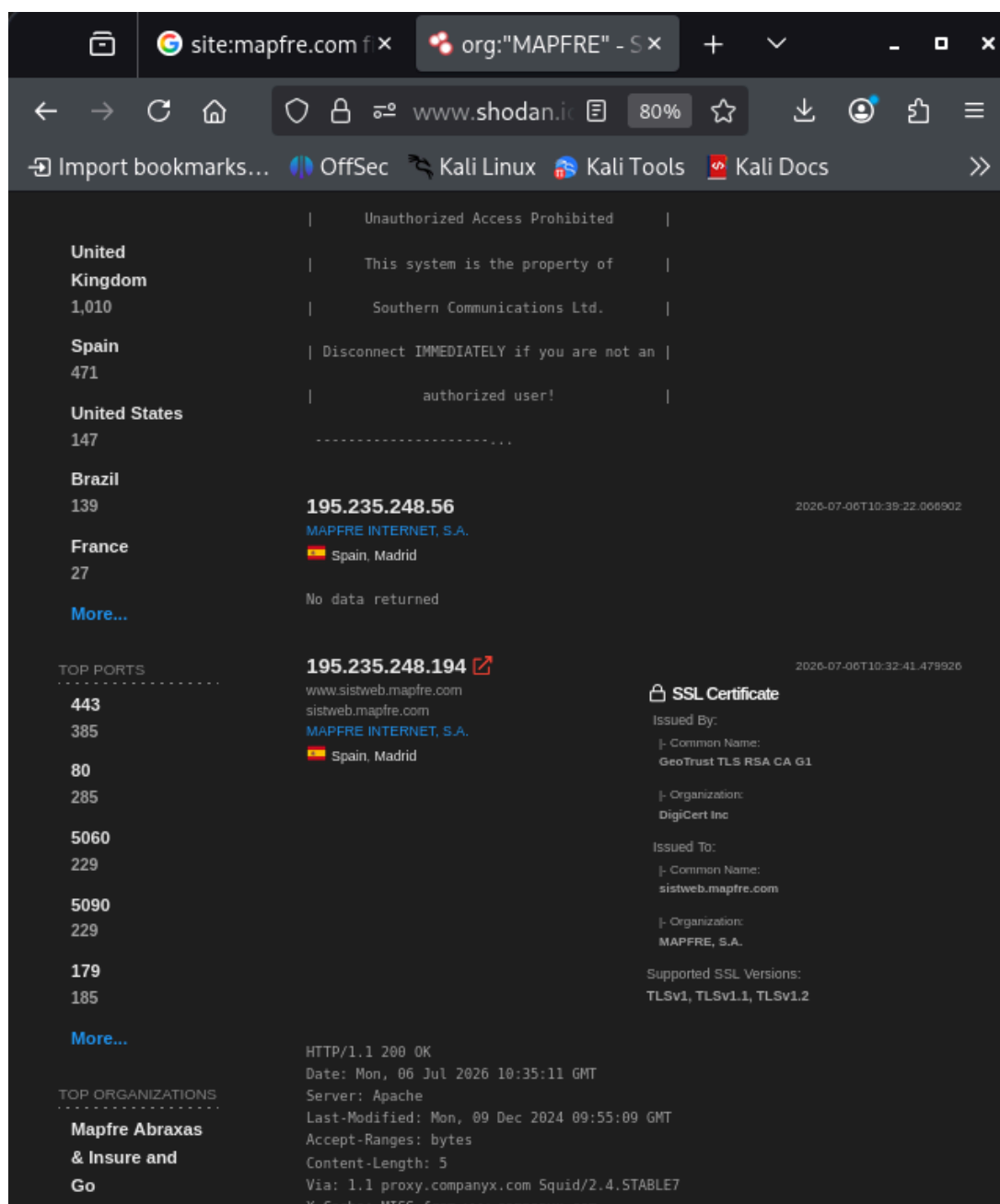


Figura 3: Resultados de la búsqueda `org:"MAPFRE"` en Shodan, mostrando distribucion geografica, puertos y hosts identificados.

3.9 Presencia en redes sociales

La pagina de empresa oficial de MAPFRE en **LinkedIn** (linkedin.com/company/mapfre) confirma varios datos ya recopilados por otras vias – sector «Seguros» y sede en Majadahonda, Comunidad de Madrid – y aporta cifras publicas de dimension: **1.188.068 seguidores** y **39.132 empleados** con perfil visible en la plataforma (ver Figura 4) [6].

Esta ultima cifra es especialmente relevante desde una perspectiva de seguridad: cada empleado con un perfil publico que declare su cargo y empresa constituye, en principio, un vector potencial para campanas de ingenieria social o **spear phishing** dirigido, especialmente si combina su nombre con el patron de nomenclatura de correo corporativo ya identificado en la seccion de Certificate Transparency (Sección 3.5). Esto refuerza la recomendacion, ya avanzada en las

conclusiones de este informe, de formar al personal – especialmente a perfiles directivos y tecnicos – sobre su propia exposicion en redes profesionales.

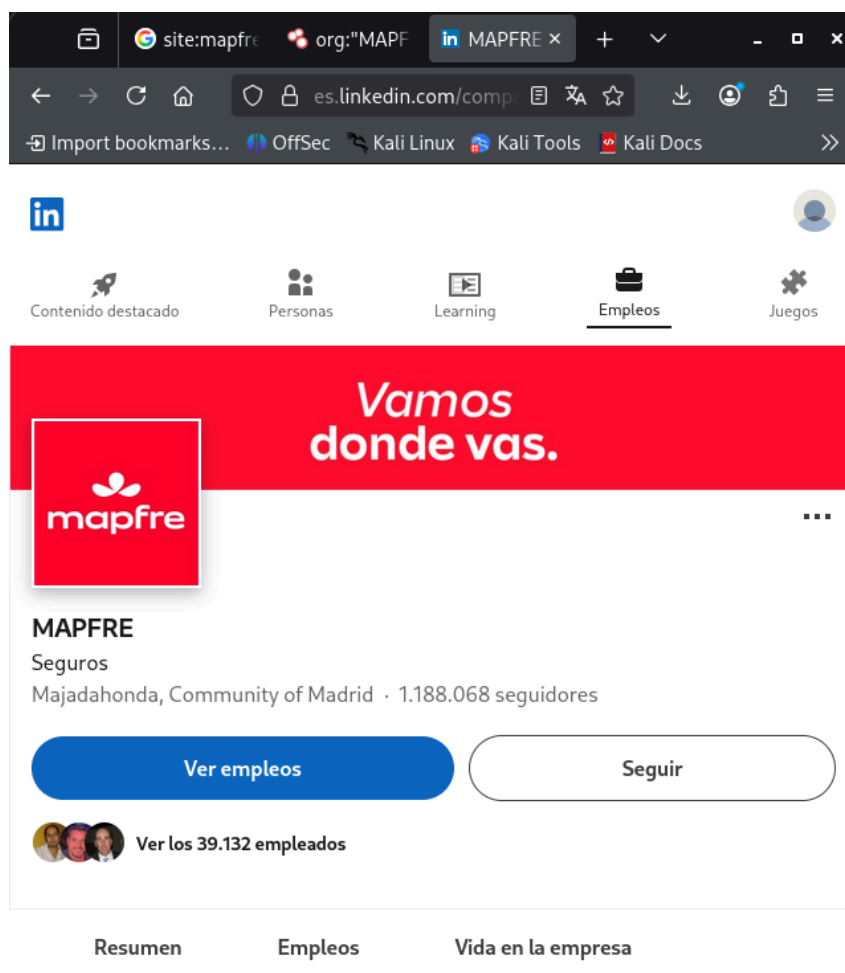


Figura 4: Pagina de empresa de MAPFRE en LinkedIn.

3.10 Google Dorking

La técnica de *Google Dorking* consiste en emplear operadores de búsqueda avanzada (`site:`, `filetype:`, `intitle:`, `inurl:`) para localizar contenido ya indexado por buscadores que no es fácilmente accesible navegando la web de forma convencional, sin necesidad de interactuar directamente con los servidores de la organización.

La búsqueda `site:mapfre.com filetype:pdf` (ver Figura 5) devuelve, entre otros resultados, un documento corporativo de 86 páginas titulado «*Keeping your trust*», alojado en `mapfre.com/media/security-mapfre`, centrado explícitamente en la protección de datos y la seguridad de la información de cara a clientes. Su existencia confirma que MAPFRE publica de forma proactiva documentación sobre su postura de seguridad, lo cual es relevante para contrastar el discurso oficial de la compañía con los hallazgos técnicos de este informe.

La misma búsqueda revela también que el subdominio `app.mapfre.com` aloja un repositorio de documentos operativos bajo la ruta `/docs/`, reutilizada por distintas líneas de negocio y países (formularios de reclamación de seguros de viaje en Irlanda, condiciones de pólizas de «Motor Pack» de MAPFRE Asistencia), lo que sugiere una plataforma de gestión documental común entre unidades de negocio muy distintas geográficamente.

Un segundo ejemplo de dorking, orientado a superficie de autentificación, consistió en buscar paneles de acceso públicamente indexados dentro del propio dominio mediante la consulta `site:mapfre.com (inurl:login OR inurl:signin OR inurl:acceso)`.

Esta búsqueda no devolvió ningún resultado. La ausencia de resultados es, en sí misma, un dato de interés: sugiere que MAPFRE no tiene paneles de autentificación indexados públicamente bajo patrones de URL predecibles en `mapfre.com`, ya sea porque los protegen mediante `robots.txt`, meta-etiquetas `noindex`, o porque sus flujos de login residen en subdominios específicos no capturados por esta consulta genérica.

Un tercer ejemplo, más original, parte de una pista encontrada de forma incidental en la cabecera `content-security-policy` de la respuesta HTTP de `www.mapfre.com` (ver Sección 3.6), que revelaba la existencia de un dominio relacionado, `mapfretecuidamos`, no detectado por ninguna de las técnicas anteriores por tratarse de un dominio independiente fuera del árbol de `mapfre.com`. La búsqueda por texto literal "`mapfretecuidamos`" confirma la existencia de `mapfretecuidamos.com`, el portal del «Club MAPFRE», un programa de fidelización de clientes con sistema de puntos («Treboles»), descuentos en marcas asociadas y un localizador de gasolineras (ver Figura 6).

Este hallazgo ilustra un principio importante del reconocimiento pasivo: el ecosistema digital real de una organización suele extenderse más allá de su dominio corporativo principal, y frecuentemente solo se descubre cruzando pistas obtenidas por técnicas distintas (en este caso, una cabecera HTTP) en lugar de limitarse a enumerar un único dominio de forma aislada.

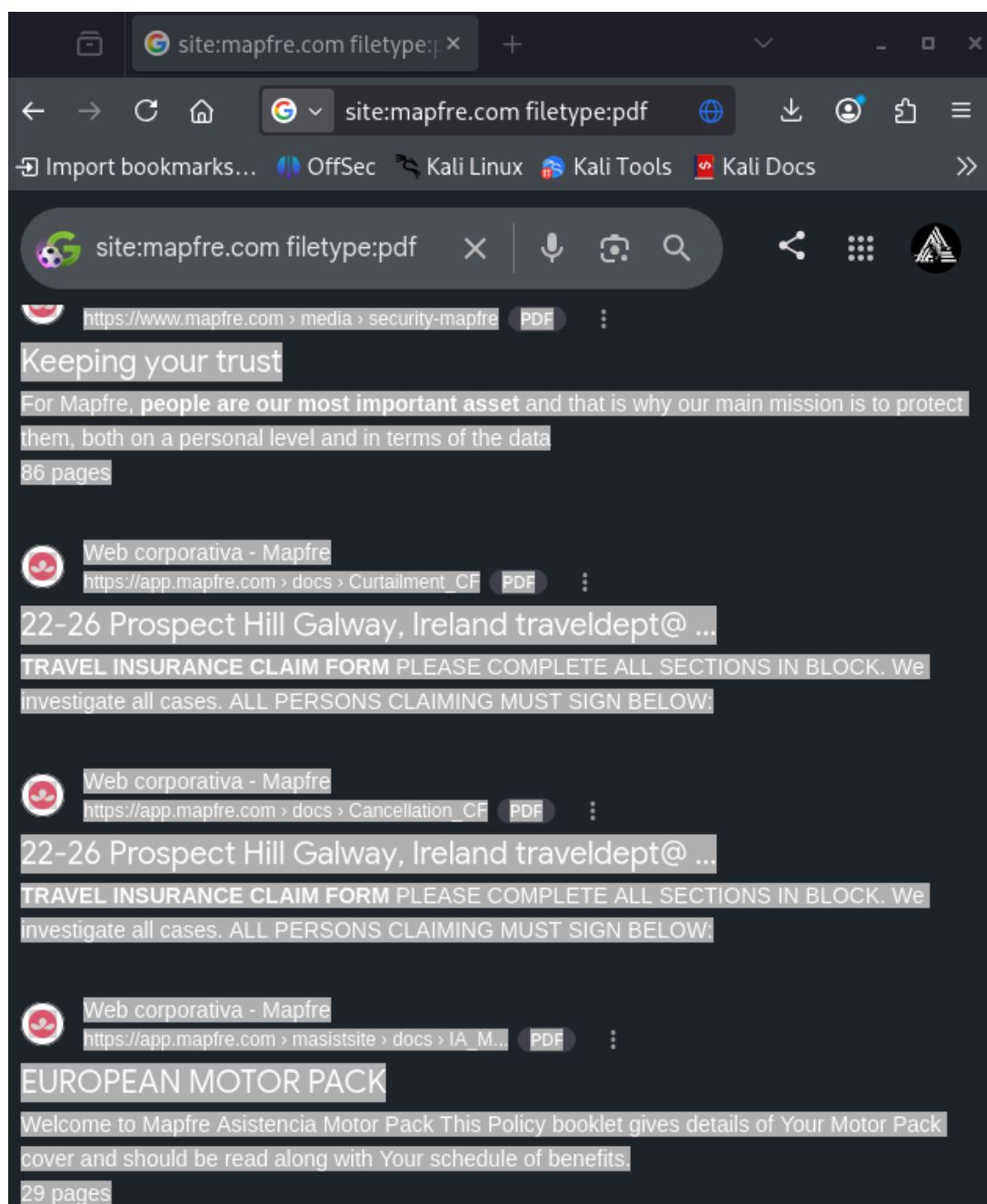


Figura 5: Resultado de la búsqueda site:mapfre.com filetype:pdf en Google.

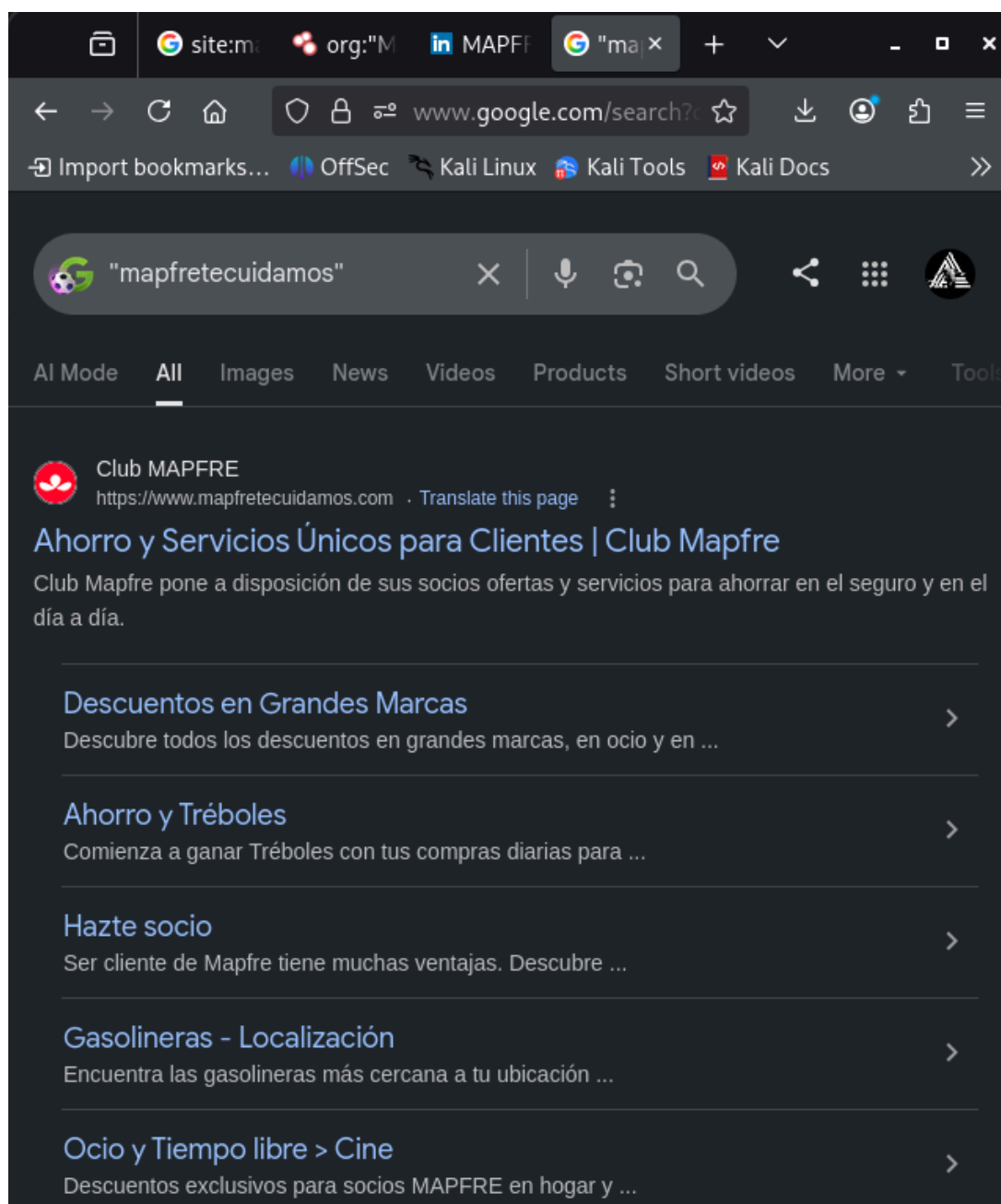


Figura 6: Resultado de la búsqueda «mapfretecuidamos», revelando el portal de fidelización Club MAPFRE en un dominio independiente.

4 Resultados

A continuación se resumen de forma tabulada los principales hallazgos de la investigación.

4.1 Identidad y registro de dominios

Dominio	Registrante	Registrador	Fecha de alta / expiración
mapfre.com	REDACTED FOR PRIVACY (WHOIS histórico: MAPFRE INTERNET, S.A.)	Acens Technologies, S.L.U.	16/03/1996 · exp. 17/03/2027

Tabla 1: Resumen de titularidad WHOIS de mapfre.com [1].

4.2 Proveedores SaaS identificados vía registros DNS TXT

Categoría	Proveedor identificado
Correo corporativo	Microsoft 365 / Exchange Online Protection
Hosting web	Amazon Web Services (eu-west-1, Irlanda)
Email marketing/transaccional	Mailjet
Seguridad de correo	Proofpoint
Observabilidad / APM	Dynatrace
Gestión de identidad	Adobe Identity Provider
Colaboración / gestión de proyectos	Atlassian (Jira/Confluence)
Marketing y verificación de propiedad	Google Search Console, Apple, Facebook Business

Tabla 2: Proveedores SaaS de MAPFRE inferidos a partir de registros TXT de verificación de dominio, obtenidos con `dig mapfre.com TXT` [2].

4.3 Categorías de subdominios expuestos (crt.sh)

Categoría	Nº hosts	Ejemplo representativo
Entornos DevOps (dev/pre/pro/pro-bis) multi-país	196	mapfrebrasil.pro.devops.mapfre.com
Plataforma MLOps «Atenea» en AWS	27	mlops.atenea.app.br.aws.mapfre.com
Módulo «bk» (banca/core) Norteamérica y Eurasia	approx. 25	previs.inteurasiabk.mapfre.com
Exchange híbrido / colaboración on-premise	5	hybridcas.mapfre.com, autodiscover.mapfre.com
Email marketing (patrón Salesforce Marketing Cloud)	4	click.comunica.mapfre.com
Stack DevOps / observabilidad	8	jenkins.tron.azure.mapfre.com, grafana.pro.devops.mapfre.com
VDI / aplicaciones virtuales	5	vdi.mapfre.com, virtualappsapi.mapfre.com
Direcciones de correo de empleados (SAN de certificados S/MIME)	approx. 10	Patrón: inicial + apellido @mapfre.com

Tabla 3: Categorización de los 527 subdominios de mapfre.com obtenidos vía Certificate Transparency (crt.sh) [3].

5 Conclusiones

El reconocimiento pasivo realizado sobre MAPFRE, S.A. demuestra que, sin necesidad de interactuar directamente con ningun sistema de la compania, es posible construir una vision razonablemente detallada de su huella digital: quien posee legalmente sus dominios, que registrador y CDN utiliza, en que paises resuelve tecnicamente su infraestructura frente a donde entrega su contenido al usuario final, que tipo de entornos internos (desarrollo, pruebas, MLOps, VDI, VoIP) tienen nombres DNS o banners publicamente indexados, cuantos empleados declaran su relacion laboral con la empresa en redes profesionales, y que dominios de marca relacionados existen mas alla del dominio corporativo principal.

Ninguno de estos hallazgos constituye, por si solo, una vulnerabilidad explotable. De hecho, varias decisiones de MAPFRE reflejan una funcion de seguridad razonablemente madura: proteccion de privacidad WHOIS, politica SPF estricta, ocultacion deliberada de la cabecera `server`, y uso de proveedores especializados en seguridad de correo (Proofpoint) y observabilidad (Dynatrace). Sin embargo, el volumen y la granularidad de los subdominios expuestos – 527 hosts unicos, el 37% correspondientes a entornos no productivos – junto con la presencia publica de aproximadamente una decena de direcciones de correo de empleados y de puertos de VoIP/BGP potencialmente sensibles indexados en Shodan, sugieren varias recomendaciones de alto nivel:

1. Revisar periodicamente la exposicion publica de nombres DNS asociados a entornos no productivos, aplicando el principio de minima exposicion (subdominios no predecibles, restriccion de resolucion publica cuando sea posible, y monitorizacion activa de nuevos certificados emitidos mediante los propios logs de Certificate Transparency).
2. Auditar la exposicion de puertos no esenciales identificados en Shodan (en particular SIP/VoIP y BGP), verificando que su exposicion publica sea intencionada y este correctamente securizada.
3. Formar al personal, especialmente a perfiles directivos y tecnicos, sobre su propia exposicion en redes profesionales como LinkedIn, dado el volumen de empleados con perfil publico (39.132) y la facilidad con la que su nombre puede combinarse con el patron de correo corporativo ya identificado para construir campañas de phishing dirigido.
4. Mantener un inventario centralizado de dominios de marca relacionados (como `mapfretecuidamos.com`, descubierto de forma incidental en este informe), de forma que su postura de seguridad se gestione de manera consistente en todo el ecosistema digital del grupo y no unicamente en el dominio corporativo principal.

Desde el punto de vista academico, este trabajo confirma el valor de las tecnicas de OSINT como primera fase, de bajo coste y sin riesgo legal, de cualquier evaluacion de seguridad, y evidencia que gran parte de la informacion «sensible» sobre la superficie de ataque de una organizacion esta ya disponible publicamente, a menudo publicada por la propia organizacion o por sus empleados y proveedores sin ser conscientes de su valor para un atacante potencial. Asimismo, el analisis critico realizado sobre los resultados de Shodan (identificando un banner perteneciente a otra organizacion por reasignacion de IP) subraya que el OSINT no consiste en acumular datos sin mas, sino en contrastar y validar cada hallazgo antes de darlo por valido.

6 Bibliografia

- [1] Acens Technologies / WHOIS registry, «Registro WHOIS de mapfre.com». 2026.
- [2] ISC - Internet Systems Consortium, «dig – DNS lookup utility (paquete dnsutils / bind9-dnsutils)». 2026.

- [3] Sectigo Limited, «crt.sh – Certificate Search (Certificate Transparency log search)». [En línea]. Disponible en: <https://crt.sh/>
- [4] ipinfo.io, «ipinfo.io – IP Address API and Geolocation». [En línea]. Disponible en: <https://ipinfo.io/>
- [5] Shodan / Shodan.io, «Shodan – Search Engine for the Internet of Everything». [En línea]. Disponible en: <https://www.shodan.io/>
- [6] LinkedIn Corporation, «Pagina de empresa de MAPFRE en LinkedIn». [En línea]. Disponible en: <https://www.linkedin.com/company/mapfre/>